Cryptography Policy

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review

Purpose

This policy establishes the principles and requirements for the use of cryptographic controls to protect the confidentiality, integrity, and authenticity of information across Stark Industries Inc.'s SaaS platform and supporting systems. This policy is aligned with ISO/IEC 27001:2022 (A.8.24 – A.8.26).

Scope

Applies to all systems, services, employees, contractors, and third-party vendors who handle or transmit classified or sensitive information within the scope of the Information Security Management System (ISMS).

Objectives

- Ensure appropriate use of encryption for data protection
- Define standards for key generation, storage, and management
- Comply with applicable industry best practices and regulatory requirements

Cryptographic Use Cases (A.8.24)

- Cryptography shall be used in the following scenarios:
    - Data in Transit: All sensitive data transmitted over public or untrusted networks (e.g. HTTP, email, APIs) must be encrypted using TLS 1.2 or higher.
    - Data at Rest: Data stored in databases, backups, and cloud storage (e.g. AWS S3, EBS volumes) must be encrypted using AES-256 or equivalent.
    - Authentication: Passwords must be stored using secure hashing algorithms (e.g. bcrypt, Argon2).
    - Code Signing and Integrity: Hashes and digital signatures are used to verify the integrity of software builds or updates.

Key Management (A.8.25)

- Key Generation

    - Keys must be generated using approved, strong algorithms and secure libraries.

    - Random number generators must be cryptographically secure.

- Key Storage
    - Private keys and encryption keys must be stored securely using hardware security modules (HSMs) or managed key services (e.g. AWS KMS).

    - Keys must not be stored in source code or CI/CD pipelines.

- Key Distribution
    - Keys must be exchanged using secure, authenticated channels only.

- Key Rotation and Expiry
    - Keys must be rotated regularly (e.g. annually or upon suspicion of compromise).
    - Expired or unused keys must be securely deleted or archived.

Acceptable Cryptographic Standards

Purpose	Minimum Requirement
TLS	TLS 1.2 or above
Data at Rest	AES-256
Password Hashing	bcrypt or Argon2
Key Exchange	ECDHE or RSA ≥ 2048 bits
Signature Algorithms	RSA ≥ 2048 bits, ECDSA

Monitoring and Review

- All cryptographic usage is reviewed annually.
- Logs of key usage and rotation are retained and auditable.
- Policy violations may result in revocation of system access and disciplinary action.

Exceptions

Any exceptions to this policy must be:

- Risk assessed

- Approved by the Information Security Manager
- Documented with a mitigation plan

Roles and Responsibilities

Role	Responsibilities
Information Security Manager	Enforces cryptographic standards and policy compliance
GRC Analyst	Maintains documentation of cryptographic controls for audits
Developers	Implement secure cryptographic functions and avoid custom crypto
Cloud/Infra Engineer	Ensure encryption is properly configured at the infrastructure level

Policy Review

- This policy is reviewed **annually** or upon significant change to the environment or regulatory requirements.